

Cybersecurity

Complete Notes

CIA Triad · Encryption · Attacks · Network Security · Authentication · Banking Security

Section	Topics	BB-তে আসার সম্ভাবনা
CIA Triad	Confidentiality, Integrity, Availability	MCQ — প্রতি বছর
Encryption	Symmetric, Asymmetric, AES, RSA, DES	MCQ + Written
Hashing	MD5, SHA, Digital Signature	MCQ
Attacks	SQL Injection, XSS, DDoS, Phishing, MITM	MCQ + Written
Network Security	Firewall, VPN, IDS/IPS, DMZ	MCQ
Authentication	Password, 2FA, Biometric, OAuth, JWT	MCQ + Written
Protocols	SSL/TLS, HTTPS, SSH, IPSec	MCQ
Banking Security	PCI DSS, ISO 27001, RTGS Security	Written

০১ CIA Triad — সবচেয়ে গুরুত্বপূর্ণ

Cybersecurity-র ভিত্তি। যেকোনো security question-এর উত্তরে CIA Triad-এর কোনো না কোনো উপাদান থাকবে।

Property	মানে	লক্ষ্য	কীভাবে নিশ্চিত করা হয়	ভাঙলে কী হয়
Confidentiality(গোপনীয়তা)	শুধু authorized user data দেখতে পারবে	Unauthorized access রোধ	Encryption, Access Control, Authentication	Unauthorized person data দেখে ফেলে
Integrity(অখণ্ডতা)	Data accurate এবং unmodified থাকবে	Data tampering রোধ	Hashing, Digital Signature, Checksum	Attacker data বদলে দেয়
Availability(প্রাপ্যতা)	System authorized user-দের কাছে সবসময় accessible থাকবে	Downtime রোধ	Redundancy, Backup, DDoS protection	System down হয়ে যায়

BB EXAM: BB AD 2025 MCQ: Email security-তে AES (Confidentiality), RSA (Integrity via signature), SHA (Integrity via hash)। Digital Signature = RSA (Asymmetric)। Email in transit = TLS।

পরীক্ষার উত্তর — CIA Triad কী? Banking-এ প্রয়োগ

CIA Triad হলো Cybersecurity-র তিনটি মূল নীতি: Confidentiality: শুধু authorized user data access করতে পারবে। Banking-এ: Account information শুধু account holder দেখবে। AES encryption, access control দিয়ে নিশ্চিত করা হয়। Integrity: Data accurate এবং unchanged থাকবে। Banking-এ: Transaction record tamper করা যাবে না। Digital Signature, Hashing (SHA-256) দিয়ে নিশ্চিত করা হয়। Availability: System সবসময় accessible থাকবে। Banking-এ: Online banking 24/7 available। Redundancy, load balancing, DDoS protection দিয়ে নিশ্চিত করা হয়।

০২ Encryption — Symmetric vs Asymmetric

Encryption মানে plaintext-কে ciphertext-এ রূপান্তরিত করা যাতে unauthorized person পড়তে না পারে।

Symmetric Encryption

একটাই key — encrypt এবং decrypt উভয়ের জন্য একই key ব্যবহার হয়।

Algorithm	Key Size	Speed	কোথায় ব্যবহার	বৈশিষ্ট্য
AES (Advanced Encryption Standard)	128/192/256 bit	দ্রুত	File encryption, Database, HTTPS	সবচেয়ে নিরাপদ symmetric
DES (Data Encryption Standard)	56 bit	দ্রুত	পুরনো system	দুর্বল — obsolete
3DES (Triple DES)	168 bit	ধীর	Legacy banking system	DES 3 বার — পুরনো
RC4	Variable	দ্রুত	WEP (WiFi)	দুর্বল — ব্যবহার বন্ধ

মনে রাখো: AES = সবচেয়ে popular symmetric algorithm | AES-256 = সবচেয়ে নিরাপদ। Bank data encryption-এ AES ব্যবহার হয়।

Asymmetric Encryption

দুটো key — Public Key (সবাই জানে) এবং Private Key (শুধু owner জানে)।

Public Key দিয়ে encrypt → Private Key দিয়ে decrypt

Private Key দিয়ে sign → Public Key দিয়ে verify (Digital Signature)

Algorithm	Key Size	Speed	কোথায় ব্যবহার	বৈশিষ্ট্য
RSA	2048/4096 bit	ধীর	Digital Signature, Key Exchange, SSL/TLS	সবচেয়ে popular
ECC (Elliptic Curve)	256 bit (= RSA 3072)	দ্রুত	Mobile, IoT, Bitcoin	ছোট key, বেশি secure
Diffie-Hellman	Variable	ধীর	Key Exchange	Direct encryption করে না
DSA (Digital Signature Algorithm)	1024-3072 bit	মাঝারি	Digital Signature only	Signature-এর জন্য

বিষয়	Symmetric	Asymmetric
Keys	একটাই (shared)	দুটো (public + private)
Speed	দ্রুত	ধীর (10-100x slower)
Key Exchange	কঠিন (secure channel লাগে)	সহজ (public key share করা যায়)
Use Case	Bulk data encryption	Key exchange, Digital Signature
Example	AES, DES, 3DES	RSA, ECC, Diffie-Hellman
Real-world	HTTPS-এর data encrypt করে	HTTPS-এর key exchange করে

BB EXAM: BB AD 2025: "Digital Signature uses which algorithm?" → RSA | "Email in transit encryption?" → TLS | "Email security uses?" → All of above (AES+RSA+SHA) |

পরীক্ষার উত্তর — Symmetric vs Asymmetric Encryption

Symmetric Encryption:

- একটাই key encrypt এবং decrypt উভয়ের জন্য • দ্রুত — bulk data-র জন্য
- সমস্যা: key secure channel-এ share করতে হয় • উদাহরণ: AES-256 (banking data encryption)

Asymmetric Encryption:

- দুটো key: Public Key (সবাই জানে) এবং Private Key (শুধু owner)
- ধীর — small data বা key exchange-এর জন্য
- সুবিধা: Public key openly share করা যায়
- উদাহরণ: RSA-2048 (Digital Signature, HTTPS key exchange) Real-world (HTTPS): Asymmetric দিয়ে session key exchange, তারপর Symmetric (AES) দিয়ে data encrypt — দুটোর সুবিধা নেওয়া।

০৩ Hashing — Data Integrity

Hash function একটা input নিয়ে fixed-size output (hash/digest) দেয়। One-way function — hash থেকে original বের করা impossible।

Hashing-এর Properties:

- **Deterministic:** একই input সবসময় একই hash দেবে
- **One-way:** Hash থেকে original বের করা যাবে না
- **Avalanche Effect:** Input একটু বদলালে hash সম্পূর্ণ বদলে যায়
- **Fixed Output:** যেকোনো size input-এ একই size output
- **Collision Resistant:** দুটো আলাদা input-এ একই hash হওয়া অসম্ভব

Algorithm	Output Size	Status	কোথায় ব্যবহার
MD5	128 bit (32 hex)	Broken — use না করো	Legacy checksum
SHA-1	160 bit (40 hex)	Weak — deprecated	পুরনো system
SHA-256	256 bit (64 hex)	Secure — সবচেয়ে popular	Password, Digital Signature, Bitcoin
SHA-512	512 bit (128 hex)	Very Secure	High security application
bcrypt	Variable	Password-এর জন্য best	Password storage (salt সহ)

Digital Signature — BB AD 2025 Exact!

Digital Signature হলো asymmetric encryption দিয়ে document-এর authenticity এবং integrity প্রমাণ করার পদ্ধতি।

- **Step 1:** Document-এর hash বের করো (SHA-256)
- **Step 2:** Hash-কে sender-এর Private Key দিয়ে encrypt করো = Digital Signature
- **Step 3:** Document + Signature পাঠাও
- **Receiver:** Signature-কে sender-এর Public Key দিয়ে decrypt করো → hash পাও
- **Verify:** Document-এর নতুন hash বের করো এবং compare করো → match = authentic

BB EXAM: BB AD 2025: "Digital Signature uses which algorithm?" → RSA। Private key দিয়ে sign, Public key দিয়ে verify।

মনে রাখো: Hashing = Integrity (data বদলায়নি)। Encryption = Confidentiality (data লুকানো)। Digital Signature = Authenticity + Integrity (কে পাঠিয়েছে + বদলায়নি)।

০৪ Common Cyber Attacks

1. SQL Injection

Malicious SQL code database query-তে inject করা হয়। Attacker unauthorized data access বা modify করতে পারে।

- **Example:** Login form-এ: username = admin'--
 - Query হয়: SELECT * FROM users WHERE username='admin'--' AND password='xxx'
 - -- মানে comment → password check skip হয়ে যায়!
- **Prevention:** Prepared Statements, Parameterized Queries, Input Validation, WAF

2. Cross-Site Scripting (XSS)

Malicious JavaScript code web page-এ inject করা। Victim-এর browser-এ চলে।

- **Stored XSS:** Malicious script database-এ save হয়, সবাই দেখলেই চলে
- **Reflected XSS:** URL-এ script, click করলে চলে
- **Prevention:** Input Sanitization, Output Encoding, Content Security Policy (CSP), HttpOnly Cookie

3. DDoS (Distributed Denial of Service)

হাজার হাজার compromised computer (botnet) থেকে একটা server-এ একসাথে request পাঠিয়ে overwhelm করা।

- **Volumetric:** Bandwidth flood (UDP flood, ICMP flood)
- **Protocol:** SYN flood — TCP handshake exhaust করা
- **Application:** HTTP flood — web server overwhelm
- **Prevention:** Rate Limiting, CDN, DDoS Protection Service (Cloudflare), Traffic Analysis

4. Phishing

Legitimate website/email-এর মতো দেখিয়ে user-এর credentials চুরি করা।

- **Email Phishing:** Fake bank email — "আপনার account block হবে, এখনই click করুন"
- **Spear Phishing:** Targeted attack — specific person-কে চেনে
- **Vishing:** Phone call-এ phishing
- **Smishing:** SMS-এ phishing
- **Prevention:** Email filtering, User awareness, 2FA, URL verification

5. Man-in-the-Middle (MITM)

Attacker দুটো communicating party-র মাঝখানে বসে। দুজনেই জানে না।

- **ARP Spoofing:** Local network-এ ARP table poison করে
- **SSL Stripping:** HTTPS → HTTP downgrade করে
- **Prevention:** HTTPS/TLS, Certificate Pinning, VPN, HSTS

6. Ransomware

Victim-এর files encrypt করে, decrypt key-এর জন্য ransom (মুক্তিপণ) চাওয়া হয়।

- **Prevention:** Regular backup, Antivirus, Email filtering, Software update, User training

7. Social Engineering

Technical exploit নয় — মানুষকে manipulate করে information বের করা।

- **Pretexting:** Fake identity তৈরি করে (IT support বলে call করা)
- **Baiting:** Infected USB ছেড়ে দেওয়া
- **Quid Pro Quo:** কিছু দেওয়ার বিনিময়ে info চাওয়া

Attack	Target	লক্ষ্য	Prevention Key
SQL Injection	Database	Data চুরি/modify	Prepared Statement
XSS	Browser	Cookie/Session চুরি	Input Sanitization
DDoS	Server	Service বন্ধ করা	Rate Limiting, CDN
Phishing	User	Credentials চুরি	2FA, Awareness
MITM	Network	Data intercept	HTTPS/TLS, VPN
Ransomware	Files	Ransom আদায়	Backup, Antivirus
Brute Force	Password	Account takeover	Strong password, Lockout

🔒 Network Security Tools

Firewall

Network traffic monitor করে এবং rules-এর ভিত্তিতে allow/block করে।

Type	কীভাবে কাজ করে	Example
Packet Filtering	IP, Port, Protocol check করে	Basic router firewall
Stateful Inspection	Connection state track করে	Enterprise firewall
Application Layer (WAF)	HTTP traffic inspect করে	Web Application Firewall
Next-Gen Firewall (NGFW)	Deep packet inspection, IPS combined	Palo Alto, Cisco

IDS vs IPS

Feature	IDS (Intrusion Detection System)	IPS (Intrusion Prevention System)
কাজ	Attack detect করে, alert দেয়	Attack detect করে, block করে
Position	Network-এ passive	Inline (traffic সরাসরি যায় এর মধ্য দিয়ে)
Action	Alert/Log only	Alert + Block/Drop
Latency	কম	কিছুটা বেশি (inspect করতে হয়)
Analogy	CCTV camera	Security guard

VPN (Virtual Private Network)

Public internet-এ encrypted tunnel তৈরি করে। Remote user secure connection পায়।

- **Site-to-Site VPN:** দুটো office-এর network connect করে
- **Remote Access VPN:** Work from home — employee office network access করে
- **Protocols:** IPSec, SSL/TLS, OpenVPN, WireGuard

DMZ (Demilitarized Zone)

Public internet এবং internal network-এর মাঝখানে একটা neutral zone। Public server (web, email) এখানে রাখা হয়।

- **Structure:** Internet → Outer Firewall → DMZ (Web/Mail Server) → Inner Firewall → Internal Network
- **কেন:** Public server compromise হলেও internal network safe থাকে

Honeypot

Fake system/service যা attacker-কে attract করে। Attacker-এর tactics জানার জন্য।

পরীক্ষার উত্তর — Firewall vs IDS vs IPS পার্থক্য

Firewall:

Pre-defined rules-এর ভিত্তিতে network traffic filter করে। Packet-এর IP, port, protocol দেখে allow/block করে। Reactive নয় — rule-based।

IDS (Intrusion Detection System): Network traffic monitor করে known attack pattern এর সাথে মিলিয়ে দেখে। Attack detect করলে alert দেয় কিন্তু block করে না।

Passive device। IPS (Intrusion Prevention System): IDS-এর মতো detect করে কিন্তু automatically block/drop করে। Inline device — সব traffic এর মধ্য দিয়ে যায়।

Summary: Firewall = Rule-based filter | IDS = Detect only | IPS = Detect + Block।

০৬ Authentication — কে তুমি প্রমাণ করো

Authentication = Identity verify করা। Authorization = কী করার permission আছে।

Authentication Factors

Factor	মানে	Example
Something you KNOW	জ্ঞান-ভিত্তিক	Password, PIN, Security Question
Something you HAVE	অধিকার-ভিত্তিক	OTP, Smart Card, Hardware Token
Something you ARE	বৈশিষ্ট্য-ভিত্তিক	Fingerprint, Face, Retina, Voice
Somewhere you ARE	অবস্থান-ভিত্তিক	GPS location, IP address
Something you DO	আচরণ-ভিত্তিক	Typing pattern, Mouse movement

Multi-Factor Authentication (MFA/2FA)

দুই বা ততোধিক factor একসাথে ব্যবহার করা। একটা compromise হলেও সুরক্ষিত।

- **2FA Example:** Password (Know) + OTP SMS (Have)
- **Banking 2FA:** ATM card (Have) + PIN (Know)
- **App 2FA:** Password + Google Authenticator TOTP

Password Security

- **Strong password:** 12+ characters, uppercase, lowercase, number, special character
- **Salting:** Random string password-এর সাথে যোগ করে hash করা — Rainbow table attack রোধ করে
- **Hashing:** Password কখনো plaintext store করবে না — bcrypt/SHA-256 দিয়ে hash করে
- **Account Lockout:** N বার ভুল password দিলে account lock → Brute force protection

OAuth 2.0 এবং JWT

"Google দিয়ে Login" = OAuth। Third-party authentication।

- **OAuth 2.0 Flow:** User → App → Google (consent) → Token → App (user info)
- **JWT (JSON Web Token):** Header.Payload.Signature — stateless authentication
 - Header: algorithm (HS256)
 - Payload: user data (id, role, expiry)
 - Signature: verify করার জন্য

BB EXAM: BB AD 2025: "Email in transit security?" = TLS। "Digital Signature?" = RSA। "JWT কী?" — তোমার REST API notes-এ আছে।

০৭ Security Protocols

Protocol	Full Form	কাজ	Port
SSL	Secure Sockets Layer	Deprecated — TLS-এর আগের version	443
TLS	Transport Layer Security	Encrypted communication (HTTPS, Email)	443
HTTPS	HTTP Secure	HTTP + TLS encryption	443
SSH	Secure Shell	Encrypted remote login	22
IPSec	IP Security	IP level encryption (VPN)	—
PGP/GPG	Pretty Good Privacy	Email encryption	—
SFTP	Secure FTP	Encrypted file transfer	22
FTPS	FTP Secure	FTP + TLS	990

TLS Handshake — কীভাবে HTTPS কাজ করে

- **Step 1:** Client → Server: "Hello, আমি এই algorithms support করি"
- **Step 2:** Server → Client: Certificate (Public Key সহ), algorithm choice
- **Step 3:** Client: Certificate verify করে, Pre-master secret তৈরি করে, Public Key দিয়ে encrypt করে পাঠায়
- **Step 4:** Server: Private Key দিয়ে decrypt করে Pre-master secret পায়
- **Step 5:** দুজনেই Session Key তৈরি করে (Symmetric)
- **Step 6:** এখন থেকে AES দিয়ে data encrypt হয়

SSL/TLS Certificate

Website-এর identity prove করে। CA (Certificate Authority) issue করে।

- **Self-signed:** নিজে sign করা — trusted না (browser warning দেয়)
- **CA-signed:** DigiCert, Let's Encrypt, Comodo — trusted
- **Wildcard:** *.example.com — সব subdomain cover করে

০৮ Banking Security — BB AD-র জন্য বিশেষ

PCI DSS (Payment Card Industry Data Security Standard)

Credit/Debit card data protect করার জন্য international standard।

- **12টা Requirements:** Network security, Cardholder data protect, Vulnerability management, Access control, Monitoring, Security policy
- **Who needs it:** যেকোনো organization যে payment card process করে
- **Levels:** Level 1 (6M+ transactions) → Level 4 (<20K transactions)

ISO 27001

Information Security Management System (ISMS)-এর international standard।

- কী করে: Organization-এর information asset identify, risk assess, control implement
- **Certification:** Third-party audit দিয়ে certify
- **Bangladesh Bank:** Scheduled banks-দের ISO 27001 compliance encourage করা হচ্ছে

Bangladesh Bank Cybersecurity Guidelines

- **NPSB Security:** National Payment Switch Bangladesh — secure transaction
- **RTGS:** Real Time Gross Settlement — high value transaction, highly secure
- **Mobile Banking:** OTP mandatory, Transaction limit, Device binding
- **Internet Banking:** 2FA mandatory, Session timeout, HTTPS

Common Banking Attacks

Attack	কী হয়	Prevention
ATM Skimming	Card data চুরি করা device লাগানো	EMV chip card, Camera monitoring
Card Cloning	Stolen data দিয়ে fake card তৈরি	EMV chip, Transaction alert
Phishing (Banking)	Fake bank site/email	2FA, URL check, Customer education
Insider Threat	Employee নিজেই data চুরি করে	Access control, Audit log, Separation of duties
Account Takeover	Credentials চুরি করে account access	2FA, Behavioral analytics, IP monitoring
SWIFT Hack	Bangladesh Bank 2016 — SWIFT system hack	Multi-approval, Real-time monitoring

পরীক্ষার উত্তর — Bangladesh Bank Cyber Heist 2016

২০১৬ সালে Bangladesh Bank-এর SWIFT (Society for Worldwide Interbank Financial Telecommunication) system hack হয়। Attacker-রা SWIFT credentials চুরি করে New York Federal Reserve-এ fraudulent transfer request পাঠায়। ৮১ মিলিয়ন USD Philippines-এ transfer হয়। মূল কারণ: Weak network security, No second approval system, Malware দিয়ে SWIFT credentials চুরি। শিক্ষা: Multi-factor approval, Real-time monitoring, Network segmentation, Regular security audit।

০৯ Cryptography — গুরুত্বপূর্ণ Concepts

Key Management

- **Key Generation:** Cryptographically secure random number generator ব্যবহার করে।
- **Key Storage:** HSM (Hardware Security Module) — tamper-proof hardware
- **Key Rotation:** নিয়মিত key বদলাও
- **Key Escrow:** Backup key authorized third party-র কাছে

PKI (Public Key Infrastructure)

Digital Certificate manage করার system।

- **CA (Certificate Authority):** Certificate issue ও sign করে (DigiCert, Let's Encrypt)
- **RA (Registration Authority):** Identity verify করে CA-কে জানায়
- **CRL (Certificate Revocation List):** Revoked certificate-এর list
- **OCSP:** Online Certificate Status Protocol — real-time revocation check

Steganography

Data লুকানোর art — file-এর মধ্যে hidden message। Encryption-এর মতো নয় — data আছে জানাই যায় না।

- **Image Steganography:** Image pixel-এ hidden message
- **Audio Steganography:** Audio file-এ hidden data

Quantum Cryptography

Quantum mechanics ব্যবহার করে theoretically unbreakable encryption।

- **QKD:** Quantum Key Distribution — interception detect হয়
- **Post-Quantum:** RSA, ECC quantum computer-এ vulnerable। NIST নতুন algorithm standardize করছে।

MCQ Quick Reference — BB Exam

প্রশ্ন	উত্তর	Source
CIA Triad কী?	Confidentiality, Integrity, Availability	BB MCQ Every Year
Email in transit encryption?	TLS (Transport Layer Security)	BB AD 2025
Digital Signature algorithm?	RSA (Asymmetric)	BB AD 2025
Email security algorithm?	All: AES + RSA + SHA	BB AD 2025
Symmetric encryption example?	AES	BB MCQ
Asymmetric encryption example?	RSA	BB MCQ
One-way function?	Hash (SHA, MD5)	BB MCQ
DDoS prevents which CIA?	Availability	BB MCQ
SQL Injection prevents which?	Confidentiality + Integrity	BB MCQ
Firewall কাজ কী?	Traffic filter by rules	BB MCQ
IDS vs IPS পার্থক্য?	IDS = detect only, IPS = detect + block	BB MCQ
2FA = কোন factors?	Know (password) + Have (OTP)	BB MCQ
HTTPS port?	443	BB MCQ
SSH port?	22	BB MCQ
Phishing কী?	Fake identity দিয়ে credentials চুরি	BB MCQ
Ransomware কী?	Files encrypt করে ransom চাওয়া	BB MCQ
VPN কী?	Public internet-এ encrypted tunnel	BB MCQ
DMZ কী?	Public ও internal network-এর মাঝে neutral zone	BB MCQ
JWT-এর ৩ অংশ?	Header.Payload.Signature	BB MCQ
PCI DSS কার জন্য?	Payment card process করা organization	BB MCQ

Cybersecurity Master Summary:

CIA = Confidentiality (AES) + Integrity (SHA/Signature) + Availability (DDoS protect)
 Symmetric = AES (fast, bulk) | Asymmetric = RSA (slow, key exchange/signature)
 Hash = One-way (SHA-256) | Digital Signature = Private key sign + Public key verify
 Attacks: SQL Injection→PreparedStmt | XSS→Sanitize | DDoS→RateLimit | Phishing→2FA